



COMMON VULNERABILITY
SCORING SYSTEM

CVSS v4.0

FIRST

MARTIN ALBERTO BENTES MARIN
PENTESTING A INFRAESTRUCTURAS DE RED

Tabla de contenido

Introducción	3
¿Qué es CVSS?	3
Conceptos de CVSS	3
Métricas Base (Base Metrics).....	3
Métricas Suplementarias (Supplemental Metrics)	4
Métricas de Amenaza (Threat Metrics)	4
Métricas Ambientales (Environmental Metrics)	4
Puntuación en CVSS v4.0 (CVSS v4.0 Scoring)	5
Tu proceso de aprendizaje	5
¿Qué hay de nuevo?.....	5
Métricas Base y Suplementarias	7
Vector de Ataque (Attack Vector)	8
Complejidad y requisitos de ataque (Attack Complexity and Requirements)	9
Privilegios Requeridos (Privileges Required).....	11
Interacción del Usuario (User Interaction)	12
Métricas de Impacto: Sistema Vulnerable y Sistemas Posteriores	13
Confidencialidad (Confidentiality)	13
Integridad (Integrity)	14
Disponibilidad (Availability)	14
Métricas Suplementarias (Supplemental Metrics).....	16
Seguridad (Safety).....	16
Automatizable (Automatable).....	16
Recuperación (Recovery)	17
Urgencia del Proveedor (Provider Urgency).....	17
Densidad de Valor (Value Density)	17
Esfuerzo de Respuesta a la Vulnerabilidad (Vulnerability Response Effort)	17
Métricas de Amenaza y Ambientales.....	19
Métricas de Amenaza (Threat Metrics).....	20
Métricas de Amenaza – Madurez del Exploit (Exploit Maturity)	20
Valores de Madurez del Exploit (Exploit Maturity)	20
Métricas Base Modificadas y Seguridad (Modified Base Metrics and Safety)	22
Valores de Métricas Base Modificadas (Modified Base Metric Values)	22
Valores de Seguridad (Safety Values)	22
Requisitos de Seguridad (Security Requirements)	24
Requisitos de Confidencialidad (Confidentiality Requirements - CR).....	24

Requisitos de Integridad (Integrity Requirements - IR)	24
Requisitos de Disponibilidad (Availability Requirements - AR)	24

Introducción

La ciberseguridad tiene una importancia cada vez mayor en el mundo digital actual. Saber cómo gestionar una vulnerabilidad —que puede dar lugar a un aumento de posibles amenazas y ataques— puede ayudar a los profesionales de seguridad a mantener sus redes e infraestructuras seguras y protegidas.

¿Cómo se identifican las vulnerabilidades de seguridad y se evalúa su gravedad? ¿Cómo puedes ayudar a identificar amenazas que exploten esas vulnerabilidades antes de que ocurran?

¿Cómo estableces prioridades para abordar las vulnerabilidades y colaboras entre distintas áreas de seguridad para implementar soluciones efectivas?

Los ejemplos y ejercicios de este curso explorarán las respuestas a estas preguntas utilizando el Sistema de Puntuación de Vulnerabilidades Comunes (CVSS). CVSS puede ser un factor clave en la priorización de vulnerabilidades.

¿Qué es CVSS?

CVSS es un estándar abierto de la industria, independiente de proveedores (vendor-agnostic), diseñado para:

- Comunicar las características y la gravedad de una vulnerabilidad de seguridad en un producto
- Proporcionar información para definir la prioridad y urgencia de la respuesta

El **Forum of Incident Response and Security Teams (FIRST)** es la organización responsable de CVSS.

FIRST es la principal organización y un líder global reconocido en la respuesta a incidentes. Su objetivo es fomentar la cooperación y coordinación en la prevención de incidentes, impulsar una respuesta rápida ante los mismos, y promover el intercambio de información entre sus miembros y la comunidad en general.

Nota: “Vendor-agnostic” significa que **CVSS no depende de Microsoft, Cisco, etc.** → es un estándar universal, por eso lo usan empresas, gobiernos y equipos de seguridad en todo el mundo.

Conceptos de CVSS

CVSS proporciona información que puedes utilizar para identificar posibles amenazas de seguridad mediante varias categorías. Estas métricas se combinan para generar una **Puntuación Base (CVSS Base Score)** y una **Cadena de Vector (Vector String)**.

Las categorías son:

Métricas Base (Base Metrics)

Las **métricas base** reflejan la gravedad de una vulnerabilidad según sus características intrínsecas, las cuales generalmente permanecen constantes a lo largo del tiempo.

Las métricas base asumen el peor escenario razonable de impacto en diferentes entornos donde el sistema esté desplegado.

Esta categoría normalmente es completada por el proveedor (supplier).

Clave para entender:

- “Intrínsecas” = propias de la vulnerabilidad (no dependen del entorno).
- Por eso el **Base Score no cambia**, mientras que otras métricas sí pueden variar.

Métricas Suplementarias (Supplemental Metrics)

El **grupo de métricas suplementarias** incluye métricas que proporcionan contexto, así como describen y miden atributos extrínsecos adicionales de una vulnerabilidad. Estas métricas son proporcionadas por el proveedor, son opcionales y no tienen impacto en la puntuación numérica final del CVSS-B.

El uso de cada métrica dentro del grupo de métricas suplementarias es determinado por quien realiza la evaluación (scoring consumer), lo que permite que un sistema de análisis de riesgo del usuario final aplique una severidad relevante según su contexto local.

Las organizaciones pueden asignar importancia y/o impacto efectivo a cada métrica, o a conjuntos de métricas, dándoles mayor, menor o incluso ningún efecto en la toma de decisiones.

Las métricas y sus valores simplemente comunican características extrínsecas adicionales de la vulnerabilidad.

Clave importante:

- Son **opcionales**
- **No afectan el score CVSS-B**
- Sirven para **contexto y toma de decisiones interna**

Métricas de Amenaza (Threat Metrics)

El **grupo de métricas de amenaza (Threat Metrics)** refleja las características de una vulnerabilidad relacionadas con la amenaza, las cuales pueden cambiar con el tiempo, pero no necesariamente entre diferentes entornos de usuario.

Por ejemplo, si se confirma que la vulnerabilidad no ha sido explotada y que no existe código de prueba de concepto (PoC) ni instrucciones disponibles públicamente, esto reducirá la puntuación CVSS resultante.

Esta categoría normalmente es completada por el consumidor (quien evalúa la vulnerabilidad).

Clave importante:

- Estas métricas **sí pueden cambiar con el tiempo** (a diferencia de las Base).
- Dependen de si la vulnerabilidad ya está siendo explotada o no.

Métricas Ambientales (Environmental Metrics)

El **grupo de métricas ambientales (Environmental Metrics)** representa las características de una vulnerabilidad que son relevantes y específicas del entorno de un usuario en particular.

Estas consideraciones incluyen la presencia de controles de seguridad que pueden mitigar algunas o todas las consecuencias de un ataque exitoso, así como la importancia relativa del sistema vulnerable dentro de una infraestructura tecnológica.

Esta categoría normalmente es completada por el consumidor (quien evalúa la vulnerabilidad).

Clave importante:

- Estas métricas **dependen totalmente del entorno**
- Ejemplo: una misma vulnerabilidad puede ser **crítica en un banco** y **baja en un laboratorio**

Puntuación en CVSS v4.0 (CVSS v4.0 Scoring)

Se asigna una **puntuación CVSS** a la vulnerabilidad de un sistema basándose en las métricas **Base, de Amenaza (Threat) y Ambientales (Environmental)**, lo que da como resultado una **clasificación cualitativa de severidad**.

La puntuación base es determinada por un investigador de seguridad u otro proveedor de evaluación, con el fin de ayudar a los consumidores a responder ante una vulnerabilidad. Las métricas de Amenaza y Ambientales son determinadas por un analista de seguridad u otra autoridad, para tomar acciones apropiadas frente a la vulnerabilidad.

La **Cadena de Vector (Vector String)** es una representación de los valores de las métricas obtenidos durante la evaluación de la vulnerabilidad.

La Vector String es una cadena de texto con un formato específico que contiene cada valor asignado a cada métrica.

Clave importante:

- Base → proveedor (researcher)
- Threat + Environmental → analista (empresa)
- Vector String → “resumen técnico” de cómo se calculó el score

Tu proceso de aprendizaje

En este curso, iniciarás un proceso de aprendizaje en el que se te introducirán los conceptos que guían la correcta identificación de amenazas de ciberseguridad.

Tendrás la oportunidad de aplicar lo aprendido asumiendo el rol de un consultor, asistiendo tanto a un investigador de seguridad (encargado de analizar las métricas Base y Suplementarias) como a un analista de seguridad (encargado de evaluar las métricas de Amenaza y Ambientales) para comprender las vulnerabilidades de ciberseguridad de sus sistemas.

En el siguiente módulo, te pondrás al día con los cambios que FIRST ha implementado en la Calculadora CVSS versión 4.0, una herramienta que utilizarás a lo largo de tu aprendizaje para evaluar la vulnerabilidad de los sistemas frente a amenazas.

¿Qué hay de nuevo?

Se han realizado varios cambios en **CVSS v4.0**:

- CVSS ya no es solo una puntuación base. Se ha introducido una nueva nomenclatura para identificar combinaciones de métricas:
 - **Base (CVSS-B)**
 - **Base + Threat (CVSS-BT)**
 - **Base + Environmental (CVSS-BE)**

- **Base + Threat + Environmental (CVSS-BTE)**
- CVSS v4.0 ofrece una mayor granularidad mediante la incorporación de nuevas métricas y valores Base:
 - Nueva métrica Base: **Requisitos de Ataque (Attack Requirements - AT)**
 - Nuevos valores en la métrica Base **Interacción del Usuario (User Interaction - UI)**:
 - Pasiva (Passive - P)
 - Activa (Active - A)
- CVSS v4.0 incluye una mejor definición de las métricas de impacto:
 - Se elimina el concepto de **Scope**
 - Se introduce una evaluación explícita del impacto en:
 - **Sistema Vulnerable:** (VC, VI, VA)
 - **Sistemas Posteriores:** (SC, SI, SA)
- El grupo de métricas **Temporal** ha sido renombrado como el grupo de métricas de **Amenaza (Threat)**
 - Las métricas de Amenaza han sido simplificadas y aclaradas
 - Las métricas **Nivel de Remediación (Remediation Level - RL)** y **Confianza del Reporte (Report Confidence - RC)** han sido eliminadas
 - La métrica **Madurez del Código de Explotación (Exploit Code Maturity)** ha sido renombrada a **Madurez del Exploit (Exploit Maturity - E)**, con valores más claros
- Se ha añadido un nuevo grupo de **métricas suplementarias (Supplemental)** para proporcionar atributos extrínsecos adicionales de una vulnerabilidad que no afectan la puntuación final CVSS-BTE:
 - **Seguridad (Safety - S)**
 - **Automatización (Automatable - A)**
 - **Recuperación (Recovery - R)**
 - **Densidad de Valor (Value Density - V)**
 - **Esfuerzo de Respuesta a la Vulnerabilidad (Vulnerability Response Effort - RE)**
 - **Urgencia del Proveedor (Provider Urgency - U)**
- CVSS v4.0 incluye un enfoque adicional en **OT/ICS (Tecnología Operacional / Sistemas de Control Industrial) y Seguridad (Safety)**:
 - Evaluación de **Seguridad (Safety)** por parte del consumidor (MSI:S, MSA:S)
 - Evaluación de **Seguridad (Safety)** por parte del proveedor mediante la métrica suplementaria **Safety (S)**

¿Qué sigue?

Es momento de comenzar tu recorrido con los escenarios interactivos de este curso mientras aprendes sobre la evaluación de severidad en CVSS.

En el siguiente módulo, iniciarás con las métricas Base y Suplementarias, antes de continuar con las métricas de Amenaza (Threat) y Ambientales (Environmental).

Métricas Base y Suplementarias

Es momento de asumir el rol de consultor mientras aprendes y aplicas conocimientos sobre las métricas base de CVSS.

Trabajarás con Helen, una investigadora de seguridad en Cyber Co., una empresa que desarrolla y vende software relacionado con aplicaciones web.

Las responsabilidades de Helen incluyen identificar vulnerabilidades en los productos de software de Cyber Co., crear parches o actualizaciones, y comunicarlos públicamente.

Helen ha identificado una vulnerabilidad en un popular framework de aplicaciones web desarrollado y licenciado por Cyber Co. Ella te ha incorporado como analista para que la asesores en la evaluación de la vulnerabilidad descubierta.



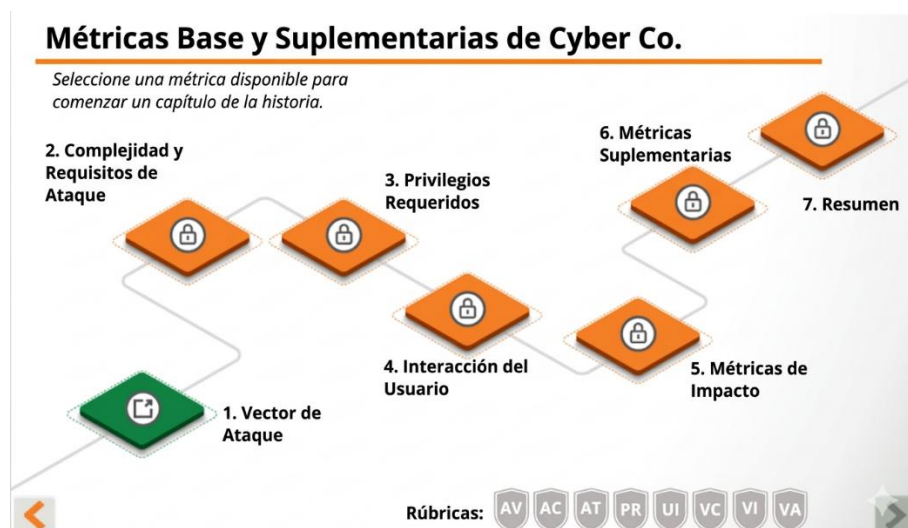
¡Bienvenido a Cyber Co.!

Esta pantalla es tu mapa de progreso mientras aprendes sobre las **Métricas Base** y las aplicas en tu rol de consultor en Cyber Co.

A medida que completes la exploración de cada métrica base, la siguiente se desbloqueará en tu mapa.

También desbloquearás **insignias de rúbrica (Rubric Badges)** en tu mapa, que te permitirán ver las guías de evaluación de las métricas base que hayas descubierto. Estas se encuentran en la parte inferior de la pantalla.

¿Listo? Comienza la historia con la primera métrica: **Vector de Ataque (Attack Vector)**.

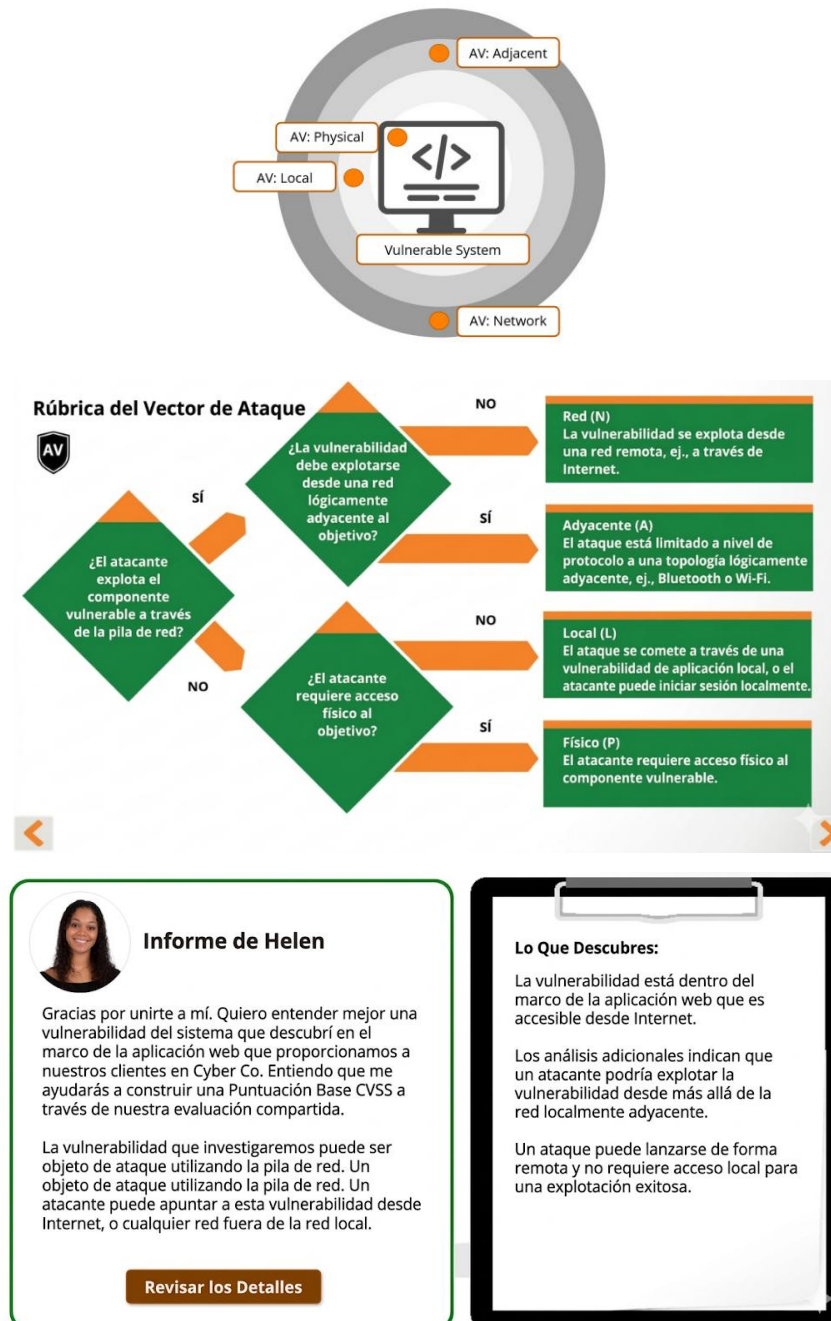


Vector de Ataque (Attack Vector)

Comencemos con la primera métrica Base: **Vector de Ataque**.

Esta métrica refleja el contexto en el cual es posible explotar una vulnerabilidad.

El Vector de Ataque representa el método más amplio mediante el cual se puede atacar el sistema vulnerable. Cuanto más amplias sean las posibles fuentes de ataque, mayor será la gravedad y, en consecuencia, la puntuación CVSS.



En este caso el vector de ataque es uno de Red. Un ataque puede explotar esta vulnerabilidad desde fuera de la red adyacente. Recuerda que **Network** se refiere a una red remota: una fuente de ataque que está fuera del entorno local y que generalmente se accede a través de Internet.

Has ayudado a Cyber Co. a determinar que su sistema tiene una vulnerabilidad de **Vector de Ataque**, clasificada como **Network (N)**. El ataque puede ejecutarse potencialmente desde cualquier fuente en Internet, sin restricciones.

Ten en cuenta que, al decidir entre **Network** y **Adjacent**, si un ataque puede lanzarse a través de una red de área amplia (WAN) o desde fuera del dominio administrativo lógicamente adyacente, se debe usar **Network**. Incluso si el atacante necesita estar dentro de la misma intranet (por ejemplo, dentro de una red corporativa), se sigue utilizando **Network**.

Elegir un valor incorrecto para el Vector de Ataque puede llevar a que quien evalúa asigne una severidad técnica y una superficie de ataque más baja de lo que realmente corresponde. Además, a medida que el valor asignado al Vector de Ataque disminuye, también disminuye la puntuación Base de CVSS.

El valor **Network** representa el peor escenario posible, debido al potencial ilimitado de quién o desde dónde puede originarse un ataque.

Complejidad y requisitos de ataque (Attack Complexity and Requirements)

Complejidad del Ataque (Attack Complexity)

La **Complejidad del Ataque** describe las condiciones que están fuera del control del atacante y que deben existir para poder explotar una vulnerabilidad.

Esta métrica considera las acciones medibles que el atacante debe realizar para evadir o superar activamente mecanismos de seguridad integrados, como **ASLR** o **DEP**.

Esta métrica está diseñada para evaluar los mecanismos de seguridad utilizados por el sistema vulnerable y no se relaciona con la cantidad de tiempo ni con el número de intentos que le tomaría al atacante tener éxito.

Requisitos del Ataque (Attack Requirements)

Los **Requisitos del Ataque** capturan las condiciones previas de despliegue y ejecución del sistema vulnerable que permiten que el ataque ocurra.

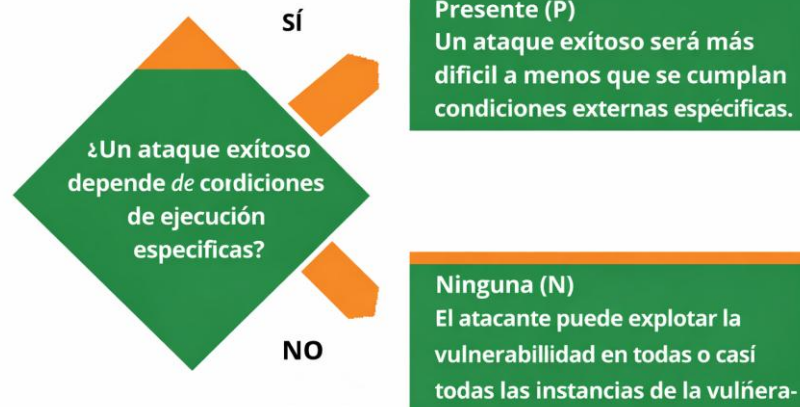
Estas condiciones se diferencian de las técnicas o tecnologías de seguridad (Complejidad del Ataque), ya que su propósito principal no es mitigar ataques, sino que surgen de forma natural debido al despliegue y funcionamiento del componente vulnerable.

El éxito del ataque depende de la presencia de condiciones específicas de despliegue y ejecución (por ejemplo, una **condición de carrera (race condition)** o una **inyección de red**) en el software vulnerable que hacen posible el ataque.

Rúbrica de Complejidad del Ataque



Requisitos de Ataque



Reporte de Helen

Pensando en la superficie de ataque de la vulnerabilidad que estamos analizando, existen dos maneras de mitigar una explotación exitosa mediante mejoras de seguridad integradas.

He descubierto que deben ocurrir múltiples eventos en una secuencia muy específica para que esta vulnerabilidad sea explotada exitosamente.

El código fuente indica que no hay medidas de seguridad integradas para defender contra tal ataque.

[Ver Detalles](#)

Lo que Descubres:

Basándose en el diseño del marco de la aplicación web, descubres que no hay mecanismos de mejora de **seguridad integrados** en el sistema. Esto reduce la complejidad necesaria para que la explotación de la vulnerabilidad tenga éxito, una vez que se cumplan los requisitos de ataque.

La explotación de la vulnerabilidad identificada solo puede ocurrir aprovechando una secuencia de tiempos muy específicos (como una **condición de carrera**). Esto puede requerir múltiples intentos de un atacante, sin éxito garantizado. El requisito de tiempo de los múltiples eventos necesarios para una explotación exitosa está fuera de la influencia directa del atacante.

Has ayudado a Cyber Co. a determinar que el ataque ocurrido con este cliente involucró una **Complejidad de Ataque Baja (Low - L)**. Esto se debe a que no existen medidas de seguridad ni técnicas de protección integradas en el sistema.

Por ejemplo, una técnica de seguridad integrada es **ASLR (Address Space Layout Randomization)**, la cual dificulta encontrar estructuras de datos en la memoria y, por lo tanto, hace más difícil su explotación.

Una clave para evaluar la **Complejidad del Ataque** es considerar si el atacante tiene control total sobre su acceso al componente vulnerable. Si existen factores externos de los que depende (como el comportamiento del usuario o momentos específicos en los que el sistema esté, por ejemplo, en mantenimiento), entonces la complejidad probablemente sea **Alta (High - H)**.

Si el atacante no depende de factores externos y puede ejecutar el ataque directamente, el valor probablemente sea **Bajo (Low - L)**.

Has ayudado a Cyber Co. a determinar que el valor asignado para **Requisitos del Ataque (Attack Requirements)** debe ser **Presente (Present - P)**. Esto se debe a que la explotación exitosa del ataque depende de superar una **condición de carrera (race condition)**.

Una condición de carrera debe “ganarse” para poder explotar la vulnerabilidad con éxito. El éxito del ataque depende de condiciones de ejecución que no están completamente bajo el control del atacante. Por ello, es posible que el ataque deba intentarse múltiples veces contra un mismo objetivo antes de tener éxito.

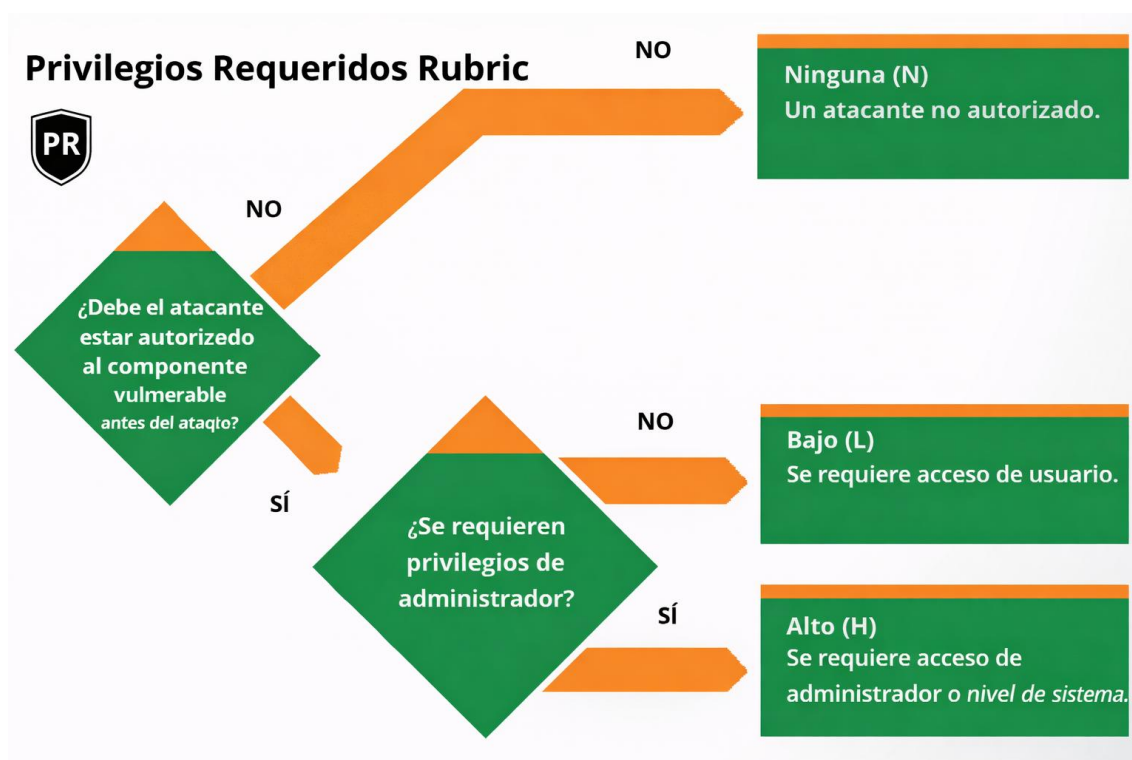
Otro ejemplo de **Requisitos del Ataque: Presente (P)** es una **inyección de red (network injection)**. Esto implica que el atacante se inserta en la ruta lógica de la red entre el objetivo y el recurso solicitado por otro usuario.

Privilegios Requeridos (Privileges Required)

Ahora exploremos los **Privilegios Requeridos**. Esta métrica describe el nivel de privilegios que un atacante debe tener antes de poder explotar con éxito una vulnerabilidad.

La pregunta clave que debes responder al evaluar esta métrica es:

¿La explotación exitosa de esta vulnerabilidad requiere que el atacante posea credenciales de autenticación específicas?



Reporte de Helen

A través de mi propio análisis y pruebas, he determinado que puedo intentar explotar la vulnerabilidad que estamos analizando sin estar autenticada.

En ningún momento necesité ingresar credenciales mientras seguía estos pasos.

Lo que descubre:

La vulnerabilidad puede ser explotada sin necesidad de autenticación del usuario (no se requieren credenciales para un ataque exitoso).

Tu análisis adicional determina que el sistema de Cyber Co. tiene una vulnerabilidad basada en red y no autenticada.

Has ayudado a Cyber Co. a determinar que los **Privilegios Requeridos (Privileges Required)** para explotar con éxito la vulnerabilidad del sistema son **None (N)**. Un atacante basado en red podría explotar esta vulnerabilidad sin necesidad de credenciales de usuario.

Considerar los privilegios como parte de una puntuación Base completa es importante. No todos los ataques requieren obtener acceso mediante privilegios. En aquellos que no lo requieren, seleccionar un valor distinto de **Privilegios Requeridos: None (N)** reduciría incorrectamente la puntuación CVSS.

Ten en cuenta que **Privilegios Requeridos** suele ser **None (N)** en vulnerabilidades como:

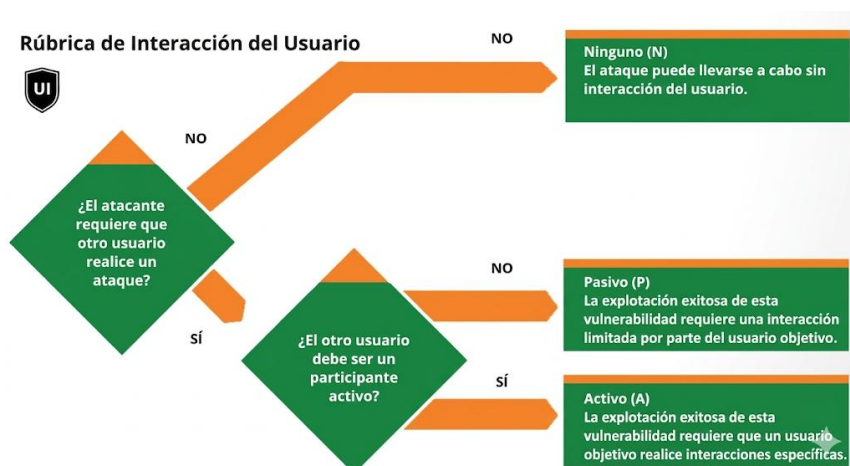
- Credenciales embebidas (hard-coded credentials)
- Vulnerabilidades que requieren ingeniería social, como:
 - **Cross-Site Scripting reflejado (XSS)**
 - **Cross-Site Request Forgery (CSRF)**
 - Vulnerabilidades en el procesamiento de archivos (por ejemplo, en lectores de PDF)

Interacción del Usuario (User Interaction)

Ahora exploremos la Interacción del Usuario.

Esta métrica indica si se requiere la participación de un usuario humano, distinto del atacante, para lograr comprometer con éxito el componente vulnerable.

Esta métrica determina si la vulnerabilidad puede ser explotada únicamente por voluntad del atacante, o si es necesario que un tercero (sin intención) participe de alguna manera.



Reporte de Helen

A partir de mi investigación, he determinado que la vulnerabilidad que estamos analizando no requiere que ninguna persona, aparte del atacante, realice alguna acción.

No parece que un atacante necesite utilizar técnicas de ingeniería social para ejecutar un ataque exitoso contra esta vulnerabilidad del sistema.

Hay algunos detalles que me gustaría que revise.

Lo que descubre:

El atacante puede explotar esta vulnerabilidad con éxito sin la asistencia ni la presencia de otro usuario interactuando con el sistema. Llegaste a esta conclusión al analizar la interacción del usuario en sus formas pasiva y activa.

- **Interacción Pasiva (Passive UI):** La explotación exitosa de una vulnerabilidad requiere una interacción limitada por parte del usuario objetivo con el sistema vulnerable y la carga maliciosa del atacante.
- **Interacción Activa (Active UI):** La explotación exitosa de esta vulnerabilidad requiere que el usuario objetivo realice acciones específicas y conscientes sobre el sistema vulnerable y la carga maliciosa del atacante.

El valor más apropiado para **Interacción del Usuario (User Interaction)** en este caso es **None (N)**. Recuerda considerar tanto la interacción pasiva como la activa:

- **Interacción Pasiva (Passive UI):** La explotación exitosa de la vulnerabilidad requiere una interacción limitada por parte del usuario objetivo con el componente vulnerable y la carga maliciosa del atacante. Estas interacciones se consideran involuntarias y no requieren que el usuario eluda activamente mecanismos de protección. Un ejemplo es navegar a un sitio web legítimo que ha sido modificado para mostrar contenido malicioso al cargarse la página.
- **Interacción Activa (Active UI):** La explotación exitosa de la vulnerabilidad requiere que el usuario objetivo realice acciones específicas y conscientes sobre el componente vulnerable y la carga maliciosa del atacante, o que sus acciones eludan activamente mecanismos de protección, lo que llevaría a la explotación de la vulnerabilidad. Ejemplos incluyen importar un archivo en una aplicación vulnerable de una manera específica o colocar archivos en un directorio determinado antes de ejecutar código.

Métricas de Impacto: Sistema Vulnerable y Sistemas Posteriores

Finalmente, exploremos las **Métricas de Impacto**. Al identificar los valores de estas métricas, quienes evalúan deben considerar tanto los impactos en el **Sistema Vulnerable** como los impactos fuera de este.

Estos impactos se definen mediante dos conjuntos de métricas:

- Impacto en el **Sistema Vulnerable**
- Impacto en **Sistemas Posteriores (Subsequent Systems)**

Confidencialidad (Confidentiality)

La **Confidencialidad** mide el impacto sobre la confidencialidad de los recursos de información gestionados por un sistema de software cuando una vulnerabilidad es explotada con éxito.

La confidencialidad se refiere a limitar el acceso y la divulgación de la información únicamente a usuarios autorizados, así como a prevenir el acceso o divulgación a usuarios no autorizados.

La puntuación resultante será mayor cuanto mayor sea la pérdida de confidencialidad en el sistema afectado.

Integridad (Integrity)

La **Integridad** mide el impacto sobre la integridad cuando una vulnerabilidad es explotada con éxito.

La integridad se refiere a la confiabilidad y veracidad de la información.

La puntuación resultante será mayor cuanto mayores sean las consecuencias en el sistema afectado.

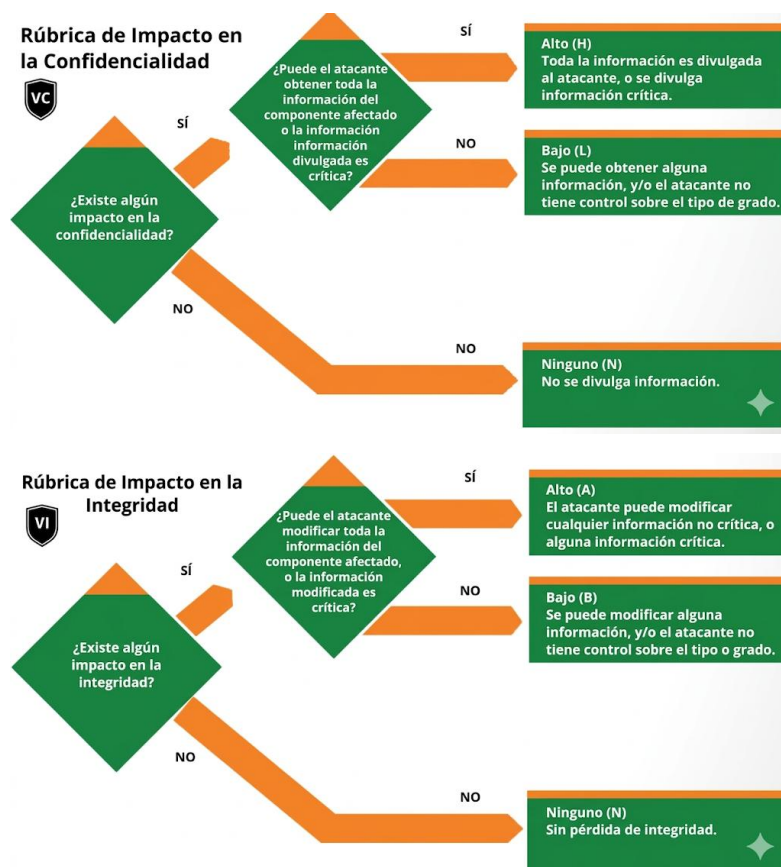
Disponibilidad (Availability)

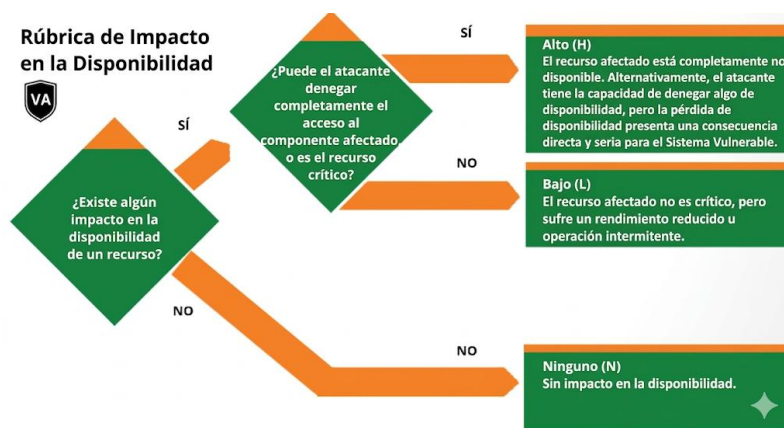
La **Disponibilidad** mide el impacto en la disponibilidad del sistema afectado como resultado de la explotación exitosa de una vulnerabilidad.

Mientras que las métricas de **Confidencialidad** e **Integridad** se enfocan en la pérdida de datos (información, archivos), esta métrica se refiere a la pérdida de disponibilidad del propio sistema afectado, como un servicio en red (por ejemplo, web, base de datos o correo electrónico).

Dado que la disponibilidad se refiere al acceso a los recursos de información, los ataques que consumen ancho de banda de red, ciclos del procesador o espacio en disco afectan la disponibilidad del sistema.

La puntuación resultante será mayor cuanto mayores sean las consecuencias en el sistema afectado.





Reporte de Helen

Lo que descubrí es que la explotación exitosa del sistema vulnerable que estamos analizando resulta en el control total de la aplicación web por parte de un atacante.

El control total implica acceso arbitrario, modificación y un impacto completo en términos de **Confidencialidad, Integridad y Disponibilidad**.

Lo que descubre:

La explotación exitosa de la vulnerabilidad resultará en un compromiso total del sistema vulnerable.

Todos los aspectos de:

- **Confidencialidad** (acceso no autorizado a datos sensibles)
- **Integridad** (capacidad ilimitada para modificar datos)
- **Disponibilidad** (tiempo de funcionamiento del sistema)

quedarían completamente bajo el control de un atacante.

No se observa un impacto directo en sistemas posteriores (Subsequent Systems) como resultado de la explotación. El impacto parece estar limitado únicamente al sistema vulnerable: el servicio de aplicación web afectado.

¡Métricas de Impacto del Sistema Vulnerable completadas!

Los valores correctos, según la información disponible, son **High (H)** para las tres métricas de impacto del **Sistema Vulnerable**.

Debido al cambio observado en la información de los pacientes antes y después del ataque, hubo un impacto **Alto (High - H)** en la **Integridad**. Al combinarse con el valor **Alto (High - H)** en **Confidencialidad**, la vulnerabilidad de este sistema —especialmente al manejar información crítica— debería ser motivo de gran preocupación para Helen.

Recuerda que la criticidad de la información se tiene en cuenta al asignar valores de impacto. Incluso si solo una parte de la información crítica puede ser alterada, el valor adecuado a asignar es **High (H)**.

¡Métricas de Impacto en Sistemas Posteriores completadas!

Los valores correctos, según la información disponible, son **None (N)** para las tres métricas: **Confidencialidad (SC)**, **Integridad (SI)** y **Disponibilidad (SA)**.

Al identificar los valores de las métricas de impacto, quienes evalúan deben considerar tanto los impactos en el **Sistema Vulnerable** como los impactos fuera de este. Estos impactos se definen mediante dos conjuntos de métricas: impacto en el Sistema Vulnerable e impacto en **Sistemas Posteriores (Subsequent Systems)**.

Al establecer los límites del sistema vulnerable dentro de la **Vector String**, los evaluadores deben utilizar el modelo conceptual de un “**sistema de interés**”.

Ten en cuenta que las métricas de explotabilidad no importan si no hay impacto. Esto significa que, si todas las métricas de impacto se establecen en **None (N)**, la puntuación permanecerá en **0** para cualquier combinación de métricas Base, Suplementarias, de Amenaza y Ambientales.

Métricas Suplementarias (Supplemental Metrics)

Las **métricas suplementarias** son un nuevo grupo de métricas opcionales proporcionadas por el proveedor (Supplier), que describen y miden atributos extrínsecos adicionales de una vulnerabilidad.

Esta información contextual puede ser utilizada de diferentes maneras en cada entorno informático, según el criterio del consumidor.

Ninguna de estas métricas tiene impacto en la puntuación final calculada de CVSS.

Las organizaciones o consumidores pueden asignar importancia o tomar acciones específicas basadas en estos valores, dándoles mayor, menor o incluso ningún efecto en la priorización.

Las métricas y sus valores simplemente comunican características extrínsecas adicionales de la vulnerabilidad.

Seguridad (Safety)

Cuando un sistema tiene un propósito o uso previsto relacionado con la seguridad física, es posible que la explotación de una vulnerabilidad en dicho sistema tenga un impacto en la **seguridad (Safety)**, el cual puede representarse dentro del grupo de métricas suplementarias.

La métrica **Safety** utiliza los siguientes valores:

- **No Definido (Not Defined - X)**
- **Negligible (N)** → Impacto insignificante en la seguridad
- **Present (P)** → Existe impacto en la seguridad

Automatizable (Automatable)

La métrica **Automatable** responde a la pregunta: “¿Puede un atacante automatizar la explotación de esta vulnerabilidad en múltiples objetivos?”

Esta métrica se basa en los pasos 1 al 4 de la **kill chain** (cadena de ataque) [Hutchins et al., 2011]:

- **Reconocimiento (Reconnaissance)**
- **Armado (Weaponization)**
- **Entrega (Delivery)**
- **Explotación (Exploitation)**

Los valores de **Automatable** son:

- **No Definido (Not Defined - X)**
- **No (N)**
- **Sí (Yes - Y)**

Recuperación (Recovery)

La métrica **Recovery** describe la capacidad de un componente o sistema para recuperar sus servicios (en términos de rendimiento y disponibilidad) después de que se haya realizado un ataque.

Los valores de **Recovery** son:

- **No Definido (Not Defined - X)**
- **Automática (Automatic - A)** → el sistema se recupera por sí solo
- **Con intervención del usuario (User - U)** → requiere acción humana para recuperarse
- **Irrecuperable (Irrecoverable - I)** → no puede recuperarse

Urgencia del Proveedor (Provider Urgency)

Para facilitar un método estandarizado que incorpore evaluaciones adicionales proporcionadas por el proveedor, CVSS ha propuesto adoptar una métrica suplementaria opcional de tipo “pass-through” llamada **Provider Urgency**.

La métrica **Provider Urgency** utiliza los siguientes niveles de urgencia:

- **Red (Rojo):** Máxima urgencia
- **Amber (Ámbar):** Urgencia moderada
- **Green (Verde):** Urgencia reducida
- **Clear:** Baja o nula urgencia

Densidad de Valor (Value Density)

La **Densidad de Valor** describe los recursos que un atacante puede controlar con un solo evento de explotación.

Los valores de **Value Density** son:

- **No Definido (Not Defined - X)**
- **Difusa (Diffuse - D)** → el impacto se distribuye en muchos sistemas o recursos
- **Concentrada (Concentrated - C)** → un solo objetivo contiene alto valor

Esfuerzo de Respuesta a la Vulnerabilidad (Vulnerability Response Effort)

El propósito de esta métrica es proporcionar información adicional sobre qué tan difícil es para los consumidores implementar una respuesta inicial frente al impacto de las vulnerabilidades en productos y servicios desplegados en su infraestructura.

El consumidor puede utilizar esta información para considerar el esfuerzo requerido al aplicar mitigaciones y/o planificar la remediación.

Los valores de **Vulnerability Response Effort** son:

- **No Definido (Not Defined - X)**

- **Bajo (Low - L)**
- **Moderado (Moderate - M)**
- **Alto (High - H)**

Reporte de Helen

Aquí es donde podría necesitar tu ayuda para determinar qué valores asignar a las métricas suplementarias en nuestro caso.

Selecciona cada métrica suplementaria para obtener más información sobre el caso y los valores adecuados a asignar.

Seguridad (Safety)

El sistema no tiene un propósito o uso previsto relacionado con la seguridad (física).

A la métrica **Safety** se le ha asignado el valor **No Definido (Not Defined - X)**.

Automatizable (Automatable)

El atacante no puede automatizar la explotación de esta vulnerabilidad en múltiples objetivos.

A la métrica **Automatable** se le ha asignado el valor **No (N)**.

Recuperación (Recovery)

La aplicación afectada por la explotación exitosa de esta vulnerabilidad se bloquea (crashea) y se reinicia automáticamente sin necesidad de intervención manual.

A la métrica **Recovery** se le ha asignado el valor **Automática (Automatic - A)**.

Urgencia del Proveedor (Provider Urgency)

Se determina que la urgencia de esta vulnerabilidad está adecuadamente representada por la puntuación base de CVSS, por lo que no es necesario definir información adicional de urgencia.

A la métrica **Provider Urgency** se le ha asignado el valor **No Definido (Not Defined)**.

Densidad de Valor (Value Density)

La densidad de valor del sistema vulnerable no puede ser definida por el proveedor del producto, ya que el valor de explotar la vulnerabilidad depende del entorno en el que esté desplegado.

A la métrica **Value Density** se le ha asignado el valor **No Definido (Not Defined - X)**.

Esfuerzo de Respuesta a la Vulnerabilidad (Vulnerability Response Effort)

Abordar esta vulnerabilidad requerirá un **esfuerzo moderado** para aplicar un parche al sistema y podría causar un impacto mínimo en el servicio.

A la métrica **Vulnerability Response Effort** se le ha asignado el valor **Moderado (Moderate - M)**.

¡Métricas Suplementarias completadas!

Has ayudado a Cyber Co. a aplicar las **Métricas Suplementarias** a su caso, de modo que Helen tenga toda la información necesaria para tomar los siguientes pasos respecto a la vulnerabilidad del sistema.

Recuerda que, si no se requiere información adicional sobre algún aspecto específico de la vulnerabilidad, es completamente válido no proporcionar respuesta (**Not Defined - X**). Además, ten en cuenta que todas las métricas suplementarias son opcionales.

El uso de cada métrica dentro del grupo de métricas suplementarias es determinado por el consumidor (quien realiza la evaluación).

Métricas de Amenaza y Ambientales

Ahora es momento de explorar las **métricas de Amenaza (Threat)** y **Ambientales (Environmental)**.

Trabajarás junto a Javier, un analista de seguridad de uno de los clientes de Cyber Co.: Metro Solutions. Como consumidor, Javier es responsable de detectar y priorizar vulnerabilidades para su remediación en Metro. Él necesitará tu ayuda para evaluar la puntuación Base.

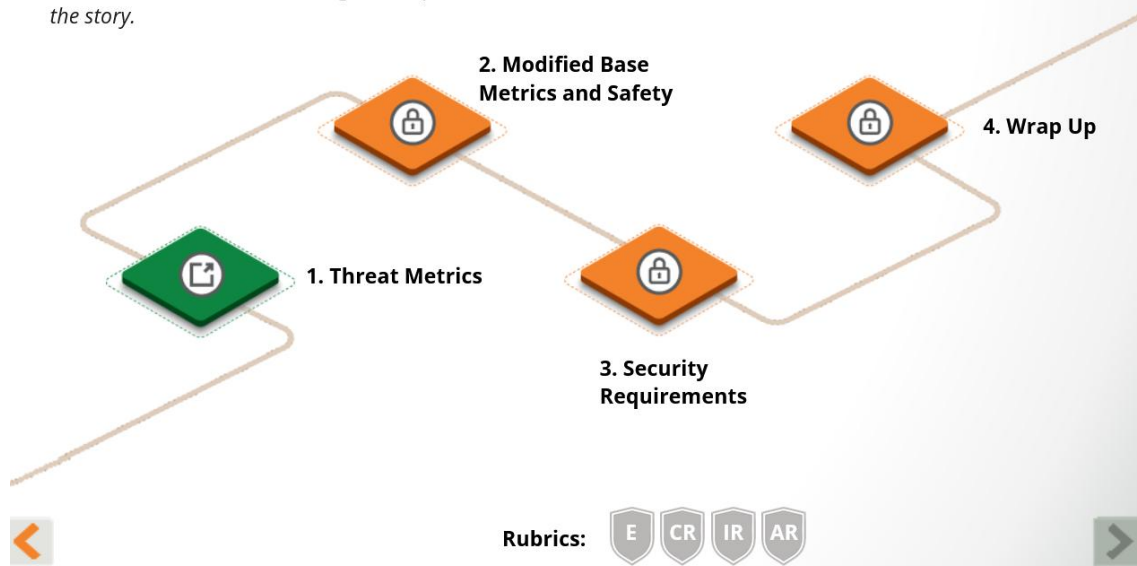
Antes de continuar, aquí tienes una visión comparativa de las métricas:

- El grupo de **Métricas Base** representa las características intrínsecas de una vulnerabilidad, las cuales permanecen constantes en el tiempo y en distintos entornos.
- El grupo de **Métricas de Amenaza (Threat)** refleja características de la vulnerabilidad que pueden cambiar con el tiempo, pero no entre diferentes entornos de usuario.
- El grupo de **Métricas Ambientales (Environmental)** representa las características de una vulnerabilidad que son relevantes y específicas de un entorno particular de usuario.



Threat and Environmental Metrics at Metro Solutions

Select an available metric to begin a chapter in the story.

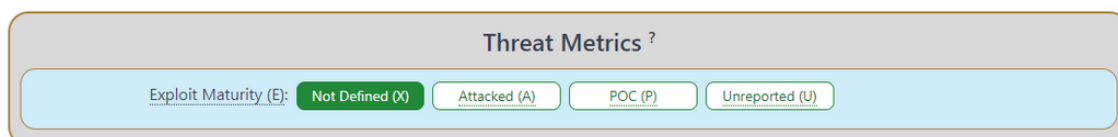


Métricas de Amenaza (Threat Metrics)

Comencemos la exploración de las métricas de Amenaza y Ambientales con las **Métricas de Amenaza**.

Las métricas de Amenaza miden el estado actual de las técnicas de explotación o la disponibilidad de código de explotación. Se espera que cambien con el tiempo y, por lo general, deben actualizarse con frecuencia.

Estas métricas se derivan de la **inteligencia de amenazas (Threat Intelligence)** recopilada por el consumidor encargado de la gestión de vulnerabilidades.



Métricas de Amenaza – Madurez del Exploit (Exploit Maturity)

La métrica de amenaza más importante es la **Madurez del Exploit (Exploit Maturity)**.

Esta métrica mide la probabilidad de que un actor malicioso intente explotar una vulnerabilidad en un sistema.

La Madurez del Exploit generalmente se basa en el estado actual de:

- las técnicas de explotación
- la disponibilidad de código de exploit
- o la explotación activa “en el mundo real” (*in the wild / in-situ*)

Valores de Madurez del Exploit (Exploit Maturity)

Existen cinco valores que pueden asignarse a la Madurez del Exploit, basados en la información recopilada por el consumidor de gestión de vulnerabilidades.

No Definido (Undefined - X)

Asignar un valor de **No Definido (Undefined - X)** indica que el atributo de **Madurez del Exploit** no está siendo utilizado. Esto se debe a que no hay inteligencia de amenazas confiable disponible para determinar sus características.

Un valor de **Not Defined** implica que los cálculos de la vulnerabilidad asumen el peor escenario posible para todas las vulnerabilidades. Asignar este valor no influirá en la puntuación resultante.

Atacado (Attacked - A)

Un valor de **Atacado (Attacked - A)** indica que fuentes de inteligencia de amenazas han determinado que se cumple al menos una de las siguientes condiciones:

- Se han reportado ataques dirigidos a esta vulnerabilidad (ya sean intentos o ataques exitosos)
- Existen soluciones que facilitan la explotación de la vulnerabilidad, disponibles de forma pública o privada (como herramientas o kits de explotación)

Prueba de Concepto (Proof of Concept - P)

Un valor de **Prueba de Concepto (Proof of Concept - P)**, también conocido como **PoC**, indica que las fuentes de inteligencia de amenazas han determinado que se cumplen todas las siguientes condiciones:

- Existe código o técnicas de prueba de concepto disponibles públicamente
- No hay conocimiento de intentos reportados de explotación de la vulnerabilidad
- No hay conocimiento de soluciones públicas que faciliten la explotación (es decir, no aplica el valor **Attacked (A)**)

No Reportado (Unreported - U)

Un valor de **No Reportado (Unreported - U)** indica que las fuentes de inteligencia de amenazas han determinado que se cumplen todas las siguientes condiciones:

- No existe conocimiento de código de prueba de concepto disponible públicamente
- No existe conocimiento de intentos reportados de explotación de la vulnerabilidad
- No existe conocimiento de soluciones públicas que faciliten la explotación (es decir, no aplican los valores **Proof of Concept (P)** ni **Attacked (A)**)



Reporte de Javier

Nuestras fuentes de inteligencia de amenazas indican que existen códigos de prueba de concepto y videos disponibles públicamente en un foro de Internet.

Lo que descubres:

Tu investigación confirma que la **Prueba de Concepto (PoC)** está disponible públicamente en múltiples fuentes en Internet.

Además de un foro, también descubriste contenido en YouTube que muestra cómo esta vulnerabilidad puede ser explotada en un entorno de laboratorio.

¡Métricas de Amenaza completadas!

Has ayudado a Javier a determinar que el valor más apropiado para **Madurez del Exploit (Exploit Maturity)** es **Prueba de Concepto (Proof of Concept - P)**. Esto se debe a que la

vulnerabilidad no está siendo explotada en el mundo real (si lo estuviera, el valor adecuado sería **Atacado (Attacked - A)**).

Basándose en la inteligencia de amenazas en tiempo real, un analista puede elegir el valor más adecuado en el momento del análisis. La inteligencia de amenazas es iterativa y cambia con el tiempo.

Métricas Base Modificadas y Seguridad (Modified Base Metrics and Safety)

Las **Métricas Base Modificadas** y **Safety** son métricas del grupo **Ambiental (Environmental)** que permiten al consumidor personalizar o ajustar los valores de la puntuación Base de CVSS según los controles de seguridad y/o arquitectónicos específicos del entorno del sistema vulnerable.

Environmental (Modified Base Metrics) ?					
Exploitability Metrics					
Attack Vector (MAV):	Not Defined (X)	Network (N)	Adjacent (A)	Local (L)	Physical (P)
Attack Complexity (MAC):	Not Defined (X)	Low (L)	High (H)		
Attack Requirements (MAT):	Not Defined (X)	None (N)	Present (P)		
Privileges Required (MPR):	Not Defined (X)	None (N)	Low (L)	High (H)	
User Interaction (MUI):	Not Defined (X)	None (N)	Passive (P)	Active (A)	

Valores de Métricas Base Modificadas (Modified Base Metric Values)

Las **Métricas Base Modificadas** brindan al consumidor la oportunidad de realizar ajustes a las métricas base según la implementación de los sistemas en sus entornos específicos.

Esto incluye controles compensatorios como:

- Firewalls
- Segmentación de red
- Funcionalidades o políticas adicionales de seguridad

También incluye otros escenarios como:

- Sistemas de seguridad e **ICS (Sistemas de Control Industrial)**
- Posibles ajustes en el impacto hacia sistemas posteriores relacionados con **OT (Tecnología Operacional)**

Valores de Seguridad (Safety Values)

Cuando un sistema puede tener implicaciones de seguridad física según cómo o dónde esté desplegado, es posible que la explotación de una vulnerabilidad tenga impactos en la seguridad (Safety). Estos pueden representarse dentro del grupo de Métricas Ambientales (Environmental).

El valor de la métrica Safety mide el impacto relacionado con la seguridad de una persona que podría resultar previsiblemente lesionada como consecuencia de la explotación de la vulnerabilidad.

A diferencia de otras métricas de impacto, Safety solo puede asociarse con el conjunto de impacto en Sistemas Posteriores (Subsequent Systems) y debe considerarse además de los valores N/L/H de las métricas de Disponibilidad e Integridad.

Se considera aplicable cuando es previsible que la explotación de una vulnerabilidad pueda causar lesiones graves o incluso peores consecuencias.

Los valores de Integridad Modificada en Sistemas Posteriores (MSI) y Disponibilidad Modificada en Sistemas Posteriores (MSA) pueden establecerse como "S" (Safety) cuando un exploit podría resultar previsiblemente en lesiones graves o peores.

Reporte de Javier

Cyber Co. ha anunciado recientemente una vulnerabilidad en un framework de aplicaciones web que se utiliza aquí en Metro. Mis escáneres de vulnerabilidades han detectado dos instancias de esta vulnerabilidad en mi entorno.

- **Escenario 1:** La primera es una aplicación web pública que recibe llamadas de emergencia del público.
- **Escenario 2:** La segunda es una aplicación web interna que muestra el menú de la cafetería para los empleados.

Necesitaré tu ayuda para evaluar ambos casos.

Lo que descubres:

Existen dos activos con la misma vulnerabilidad:

- **Escenario 1:** Una aplicación web externa que recibe llamadas de emergencia. Si la disponibilidad o integridad de esta aplicación se ve afectada, la vida de personas podría estar en riesgo.
- **Escenario 2:** Una aplicación web interna que muestra el menú de la cafetería. Esta aplicación está en una red aislada sin conectividad hacia o desde Internet. Solo la red local (LAN) puede acceder al sistema.

Abordaste el primer escenario. Siguiente: el segundo.

Identificaste que tanto la Integridad Modificada en Sistemas Posteriores (Modified Subsequent Integrity - MSI) como la Disponibilidad Modificada en Sistemas Posteriores (Modified Subsequent Availability - MSA) son las métricas que deben ajustarse.

Trabajando con Javier, asignaste a ambas el valor de Seguridad (Safety - S).

En circunstancias normales, el impacto en Integridad y Disponibilidad sería Alto (High - H). Sin embargo, debido al riesgo potencial para la vida humana que podría derivarse de una pérdida de integridad o disponibilidad en este sistema crítico, es más apropiado actualizar estos valores a Safety (S).

¡Métricas Base Modificadas y Safety completadas!

Identificaste que la métrica base modificada correcta a ajustar para esta vulnerabilidad es el **Vector de Ataque Modificado (Modified Attack Vector - MAV)**.

Aunque la vulnerabilidad podría haberse explotado desde Internet, determinaste que **Adjacent (Adyacente)** es el valor más apropiado a asignar.

Requisitos de Seguridad (Security Requirements)

El grupo de métricas de **Requisitos de Seguridad** identifica tres métricas para medir la criticidad del sistema vulnerable.

Estas métricas permiten al analista personalizar la puntuación CVSS según la importancia del activo de TI afectado para la organización, evaluado en términos de **Confidencialidad, Integridad y Disponibilidad**.

Si un activo de TI soporta una función del negocio en la que la **Disponibilidad** es lo más importante, el analista puede asignar un mayor valor a las métricas relacionadas con la disponibilidad.

Cada requisito de seguridad tiene tres valores posibles:

- **Bajo (Low)**
- **Medio (Medium)**
- **Alto (High)**

Requisitos de Confidencialidad (Confidentiality Requirements - CR)

El Requisito de Confidencialidad (CR) de un sistema debe basarse en el nivel de clasificación de los datos que se almacenan o utilizan por el usuario y/o las aplicaciones que se ejecutan en el sistema objetivo.

El cifrado de los datos en reposo en este dispositivo también debe considerarse al establecer el Requisito de Confidencialidad.

Los datos que pasan a través de un dispositivo sin ser consumidos o procesados (por ejemplo, un switch o firewall) no deben ser considerados al evaluar este atributo.

Requisitos de Integridad (Integrity Requirements - IR)

Los **Requisitos de Integridad (IR)** de un sistema se centran en la importancia de la exactitud de los datos que almacena o utiliza.

Los datos que pasan a través de un dispositivo sin ser consumidos o procesados (por ejemplo, un switch o firewall) no deben ser considerados al evaluar este atributo.

El uso de cifrado en los datos en reposo no debe tenerse en cuenta para este atributo.

Requisitos de Disponibilidad (Availability Requirements - AR)

El **Requisito de Disponibilidad (AR)** de un sistema debe basarse en los requerimientos de tiempo de actividad (*uptime*) y en la redundancia del dispositivo o de las aplicaciones que este aloja.

Los dispositivos que forman parte de clústeres redundantes tendrán menores requisitos de disponibilidad.

Confidencialidad Requisitos Rúbrica



Bajo (B)
La pérdida probablemente tendrá solo un efecto adverso limitado en la organización o en los individuos.

Medio (M)
La pérdida probablemente tendrá un efecto adverso grave en la organización o en los individuos.

Alto (A)
La pérdida probablemente tendrá un efecto adverso catastrófico en la organización o en los individuos. ✨

Rúbrica de Requisitos de Integridad



Bajo (B)
La pérdida probablemente tendrá solo un efecto adverso limitado en la organización o los individuos.

Medio (M)
La pérdida probablemente tendrá un efecto adverso grave en la organización o los individuos.

Alto (A)
La pérdida probablemente tendrá un efecto adverso catastrófico en la organización o los individuos. ✨

Disponibilidad Requisitos Rúbrica



Bajo (B)
La pérdida probablemente tendrá solo un efecto adverso limitado en la organización o en los individuos.

Medio (M)
La pérdida probablemente tendrá un efecto adverso grave en la organización o en los individuos.

Alto (A)
La pérdida probablemente tendrá un efecto adverso catastrófico en la organización o en los individuos. ✨

Informe de Javier

Ya he completado una evaluación y he documentado estos valores en mi base de datos de gestión de activos, por lo que puedo aplicar automáticamente los valores a todas las vulnerabilidades encontradas en estos sistemas.

El **Requisito de Confidencialidad** es **Bajo**, ya que esta información está clasificada como pública en ambos escenarios.

Sin embargo, el **Requisito de Integridad** para el sistema de emergencia (**Escenario 1**) sería **Alto**, mientras que el **Requisito de Integridad** para el menú de la cafetería (**Escenario 2**) sería **Bajo**. Si un atacante modificara la información en una llamada de emergencia, podría interferir

con los servicios de emergencia y poner en riesgo vidas humanas. Las consecuencias de alterar un menú de cafetería no son graves.

El **Requisito de Disponibilidad** será el mismo: **Alto** para el sistema de emergencia y **Bajo** para el menú de la cafetería, siguiendo la misma lógica.